

Identification des surfaces d'attaques de la 5G

Contents

1.1	Nouveautés apportées par la 5G	1
1.1.1	Changement de paradigme	2
1.1.2	Evolution des interfaces et piles protocolaires	2
1.1.3	Développement des réseaux privés	3
1.1.4	Ecosystème élargi et nouveaux vecteurs d'intrusions	3
1.2	Architecture, composants et protocoles	4
1.2.1	Composants physique du réseau	4
1.2.2	Canaux de communication et protocoles associés	6
1.3	Définition du cadre d'étude de la thèse	7

Les réseaux 5G sont conçus pour répondre à des exigences strictes en terme de haut débit (eMBB), de faible latence (URLLC) et de communications massives entre appareils connectés (mMTC), permettant l'émergence de nombreux services innovants[?, ?]. Pour assurer la mise en œuvre et le fonctionnement efficace de ces différents cas d'usage, la 5G change profondément de paradigme et intègre plusieurs nouveaux concepts aux réseaux mobiles, de nouveaux composants dans son architecture et de nouvelles méthodes de communications entre les entités qui la composent.

Ces évolutions rendent les réseaux mobiles plus flexibles et plus dynamiques mais au prix d'une complexification du système et d'une augmentation de la surface d'attaque. Dans ce contexte, les besoins en matière de détection d'anomalies évoluent également et il devient alors nécessaire de concevoir de nouveaux mécanismes de détection capables de s'adapter aux spécificités et à la complexité des architectures 5G.

1.1 Nouveautés apportées par la 5G

Cette section présente les principales évolutions introduites par la 5G par rapport aux générations précédentes de réseaux mobiles. Ces changements concernent à la fois l'architecture du réseau, les protocoles de communication, ainsi que l'écosystème global dans lequel s'inscrivent ces systèmes. Ils ont un impact direct sur la surface

d'attaque du réseau et constituent donc un élément central pour l'analyse des menaces et des vulnérabilités.

1.1.1 Changement de paradigme

La virtualisation constitue la base technologique qui permet des fonctions avancées telles que le network slicing. Elle repose sur deux concepts clés, NFV et SDN, qui permettent de déployer des services à la demande sur tout type de matériel. Grâce à ces approches, les réseaux 5G s'éloignent de la conception traditionnelle des systèmes mobiles, historiquement construits sous forme d'architectures monolithiques où chaque fonction s'exécutait sur un matériel dédié et communiquait via des canaux fixes et des piles de protocoles rigides. À la place, l'architecture 5G adopte une approche plus proche de celle des microservices du cloud, où les fonctions réseau sont softwarisées, découplées et conteneurisées.

Cependant, malgré les avantages significatifs de la virtualisation, celle-ci hérite également d'un nombre important de nouvelles vulnérabilités propres à cette technologie. En effet, qu'elle repose sur des technologies de machines virtuelles ou sur la conteneurisation, la virtualisation représente une couche supplémentaire qui peut elle-même être vulnérable à des attaques spécifiques tel que l'empoisonnement d'image [?] ou l'évasion de VM/Docker [?, ?].

1.1.2 Simplification des interfaces et piles protocolaires

Les interfaces étaient initialement conçues pour des entités fixes et présentaient donc une certaine rigidité. Elles reposaient souvent sur des protocoles très spécifiques, répondant à des problématiques bien définies. Le changement de paradigme de la 5G vers celui des systèmes distribués, ainsi que la volonté de rendre les réseaux plus flexible, entraînent donc une simplification de ces interfaces et protocoles.

Certains protocoles et interfaces restent tout de même hérités de la 4G sont conservés en 5G, ce qui implique que cette dernière hérite d'une partie de la surface d'attaque et des vulnérabilités des générations précédentes. On retrouve par exemple des attaques d'injection de messages de contrôle dans le flux utilisateur géré par le protocole GTP-U [?, ?], des attaques par inondation ciblant la gestion des ressources radio via le protocole RRC [?], ainsi que des attaques par rejeu affectant les messages de signalisation du protocole NAS [?].

Mais la transition vers une architecture inspirée des microservices introduit aussi de nouvelles interfaces et de nouveaux protocoles, élargissant par conséquent la surface d'attaque. L'adoption des Service-Based Interfaces (SBI), basées sur des API REST, expose notamment le cœur de réseau à des attaques de type fuzzing [?]. De nouveaux protocoles comme NGAP peuvent être ciblés par des injections de messages malformés [?], tandis que PFCP introduit de nouvelles surfaces d'attaque liées à la gestion des sessions et des flux [?].

1.1.3 Développement des réseaux privés

La simplification de l'architecture 5G facilite aussi le déploiement et l'exploitation de réseaux mobiles privés. Cette approche offre à certaines organisations, telles que les universités, les hôpitaux ou encore les bases militaires, la possibilité de gérer leur propre infrastructure. Elles peuvent ainsi, entre autre, bénéficier d'un contrôle complet de leur couverture réseau, ainsi que de la gestion de sa sécurité. [?]

Cette dynamique est facilitée par la disponibilité croissante d'implémentations open source permettant de construire des réseaux 5G de manière autonome. Toutefois, ces solutions présentent encore des limites importantes. Leur niveau de maturité reste relativement faible et certains mécanismes de sécurité fondamentaux peuvent être encore absents. Malgré ces lacunes, ces technologies open source sont déjà utilisées dans des contextes réels, parfois après adaptation par des acteurs industriels. C'est par exemple le cas de Firecell[?] qui réutilise une version consolidée de l'implémentation open source d'Open Air Interface (OAI)[?].

À l'heure actuelle, la 5G privée demeure un marché de niche, en partie en raison du manque de maturité des solutions disponibles. Néanmoins, les perspectives de croissance sont importantes et une adoption plus large est attendue dans les années à venir. Dans ce contexte, le recours massif à des implémentations open source ou à leurs dérivés commerciaux pourrait engendrer des risques significatifs en matière de sécurité, notamment si les insuffisances actuelles ne sont pas pleinement corrigées.

1.1.4 Ecosystème élargi et nouveaux vecteurs d'intrusions

La softwarisation et la simplification de l'architecture 5G ont pour objectif d'étendre l'usage de la 5G au secteur industriel. Les besoins des entreprises et de leurs utilisateurs étant variés, la 5G introduit de nouveaux mécanismes dans les réseaux mobiles afin d'y répondre. Cependant, l'ajout de nouvelles fonctionnalités entraîne également de nouvelles problématiques de sécurité ainsi que de nouveaux vecteurs d'intrusion. Parmi les nombreuses innovations apportées par la 5G, plusieurs exemples notables contribuent à l'élargissement de la surface d'attaque.

- **Slicing** : Afin de gérer efficacement plusieurs services et cas d'usage, la 5G introduit le concept de network slicing qui consiste à créer plusieurs réseaux virtuels au sein d'une même infrastructure physique partagée. Le concept de slicing impacte l'architecture 5G à tous les niveaux, depuis la couche physique, où il implique la gestion de la grille de ressources temps/fréquence [?], jusqu'à la couche applicative, où il garantit la continuité et l'isolation des services. Bien que les spécifications du 3GPP relatives aux slices intègrent des mécanismes de sécurité robustes [?, ?], les implémentations actuelles, en particulier open source, restent encore immatures. Cette situation soulève des préoccupations de sécurité et introduit de nouveaux vecteurs d'attaque, notamment liés à une isolation imparfaite et au partage de ressources physique.

- **Orchestrations** : Dans un déploiement à grande échelle, il n'est pas réaliste de gérer l'entiereté de l'infrastructure des réseaux 5G manuellement. La virtualisation des fonctions réseaux permet cependant d'automatiser l'orchestration et la gestion des services [?] pour pouvoir moduler, en fonction des besoins, l'architecture et les capacités du réseaux. Cette gestion automatisée est généralement réalisée par des logiciels comme Kubernetes ou Openstack qui rajoutent des couches de complexité et de vulnérabilités.
- **Chaîne d'approvisionnement** : L'intégration logicielle était historiquement gérée par un acteur unique : le fournisseur d'équipements réseau. Cependant, les réseaux 5G reposent maintenant sur un bien plus grand panel de logiciels pour leur fonctionnement. Comme c'est généralement le cas dans le développement logiciel moderne, ces logiciels reposent largement sur du code tiers, dont une grande partie est open source. Cela introduit des risques liés à la méconnaissances de l'inventaire détaillé des composants logicielle (Software Bill of Materials) ainsi qu'aux attaques de la chaîne d'approvisionnement [?, ?, ?, ?, ?].

1.2 Architecture, composants et protocoles

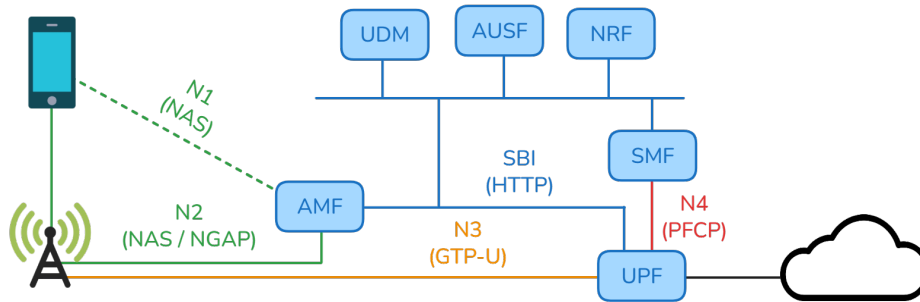


Figure 1.1: Illustration simplifiée des principaux composants de l'architecture 5G

L'architecture 5G repose sur un ensemble distribué de composants interconnectés, organisés en plusieurs sous-systèmes coopérant pour assurer la connectivité et la gestion des communications. Bien que de nombreux autres éléments existent, les composants présentés ci-dessous comptent parmi ceux absolument essentiels au fonctionnement du réseau 5G. La Figure ?? en propose une illustration simplifiée. Nous allons maintenant décrire les différents composants de l'architecture représentée, ainsi que les protocoles utilisés pour assurer les communications entre ces entités.

1.2.1 Composants physique du réseau

1.2.1.1 Equipements Utilisateurs (UE)

Les UE désignent les dispositifs qui se connectent au réseau 5G, tels que les smartphones, les objets connectés et, plus généralement, tout équipement disposant d'une interface radio par laquelle ils peuvent communiquer avec le réseaux 5G. Ils constituent la grande majorité des entités actives du réseau et représentent, par nature, les composants les plus exposés de l'infrastructure. En raison de leur nombre, de leur vulnérabilité et de leur accessibilité, ils sont à la fois les cibles mais aussi les vecteurs les plus probables lors d'une attaque [?, ?, ?].

Du point de vue d'un attaquant, compromettre un UE peut s'avérer relativement simple. L'accès peut être réalisé à distance, par installation de logiciels malveillants, ou physiquement, en dérobant l'appareil la carte SIM qui l'authentifie. Bien que les UE ne soient capable d'interagir directement qu'avec la station de base, ils peuvent par exemple être exploités pour mener des attaques par déni de service distribué (DDoS).

1.2.1.2 Réseaux d'accès radio (RAN)

Les UE se connectent au cœur de réseau via le RAN, composé d'un ensemble de stations de base radio, appelé gNB et éventuellement complété par d'autres relais radio. Le gNB assure l'interface avec le cœur de réseau via l'AMF, ainsi qu'avec le réseau de données via l'UPF auquel il est connecté par liaison IP standard. Le gNB prend en charge les communications radio, la gestion de l'accès et de l'ordonnancement des ressources, et garantit la continuité de service grâce aux mécanismes de handover entre stations de base voisines.

Contrairement aux réseaux 4G, les réseaux 5G reposent sur un déploiement beaucoup plus dense de stations radio, situées plus près des utilisateurs finaux. Cette proximité accrue facilite l'accès physique pour des attaquants susceptibles de tenter de prendre le contrôle de ces équipements. De plus, les gNB sont relativement faciles à usurper pour un adversaire en raison de l'absence de mécanisme d'authentification forte vis-à-vis des UE. En effet, en émettant un signal plus puissant que celui des stations de base légitimes à proximité, un attaquant peut inciter les terminaux environnants à se connecter à leur station malhonnête en priorité[?]. Ces attaques sont d'autant plus facilitées par la disponibilité croissante d'outils de radio définie par logiciel (SDR), qui nécessitent relativement peu de ressources et de compétences techniques pour être utilisés.

1.2.1.3 Coeur de réseaux (CN)

Le cœur de réseau (CN) est un ensemble de fonctions réseau interconnectées via une infrastructure IP, qui interagissent entre elles ainsi qu'avec les UE et les gNB à travers des chaînes de procédures. Ces fonctions assurent chacune un rôle spécifique et un grand nombre d'entre elles sont définies par le standard 3GPP. Certaines sont

essentielles au fonctionnement du réseau, tandis que d'autres répondent à des cas d'usage plus spécifiques et ne sont donc pas systématiquement déployées. Parmi les fonctions réseau essentielles, on retrouve notamment :

- **AMF (Access and Mobility Management Function)** : gère l'enregistrement des UEs, la mobilité et la signalisation.
- **SMF (Session Management Function)** : responsable de l'établissement, de la modification et de la libération des sessions PDU.
- **UPF (User Plane Function)** : assure le transfert des données utilisateur et le routage vers les réseaux externes.
- **AUSF (Authentication Server Function)** : réalise les procédures d'authentification des utilisateurs.
- **UDM (Unified Data Management)** : gère les données d'abonnement et les profils des utilisateurs.
- **NRF (Network Repository Function)** : permet la découverte et l'enregistrement des fonctions réseau.

Le CN est significativement plus difficile d'accès que les UEs ou les gNBs, car les machines physiques qui les hébergent ne sont généralement pas exposées à un accès physique direct. Néanmoins, en raison de leur forte valeur stratégique, compromettre une fonction réseau reste un objectif réaliste pour un adversaire déterminé. Comme évoqué dans les sections précédentes concernant l'orchestration et la chaîne d'approvisionnement, il demeure possible d'atteindre le cœur de réseau pour compromettre certains de ses éléments et obtenir un accès direct au reste du CN. Cet accès pourrait notamment être utilisé pour altérer l'architecture du cœur de réseau en ciblant le NRF[?], exposer des données utilisateur via l'UDM[?], et perturber la gestion des sessions en interférant avec la communication entre le UPF et le SMF[?].

1.2.2 Canaux de communication et protocoles associés

En 5G, plusieurs canaux de communication coexistent, chacun remplissant un rôle spécifique et s'appuyant sur des protocoles dédiés. Certains de ces protocoles, tels que GTP-U et NAS, sont hérités des générations précédentes de réseaux mobiles. À l'inverse, la 5G introduit également de nouveaux protocoles, comme NGAP et PFCP, spécifiquement conçus pour répondre aux besoins des nouvelles architectures 5G. Dans notre étude, nous nous concentrons plus particulièrement sur les protocoles de niveau applicatif qui sont, de notre point de vue, les plus représentatifs du changement de paradigme introduit par la 5G vers des systèmes distribués. Parmi les protocoles de communications principaux, on retrouve notamment :

- **Packet Forwarding Control Protocol (PFCP)** est utilisé entre le SMF et l'UPF sur l'interface N4 pour la gestion des sessions utilisateur.
- **GPRS Tunnelling Protocol - User Data (GTP-U)** encapsule les données utilisateurs émises par l'UE. Ces paquets sont ensuite acheminés via l'UPF par le gNB sur l'interface N3.
- **Next Generation Application Protocol (NGAP)** assure la gestion des échanges de signalisation entre le gNB et l'AMF sur l'interface N2.
- **Non-Access Stratum (NAS)** est utilisé par l'UE pour communiquer avec l'AMF via l'interface N1. Bien que cette interface soit logiquement définie comme de bout en bout, elle est en pratique virtuelle, les messages NAS étant relayés de manière transparente par le gNB.
- **Hypertext Transfer Protocol/2 (HTTP/2)** est utilisé pour les communications entre fonctions réseau via le Service Based Interface (SBI).

1.3 Définition du cadre d'étude de la thèse

Comme présenté dans les sections précédentes, l'écosystème et la surface d'attaque de la 5G se sont considérablement élargis par rapport aux générations précédentes, formant plusieurs domaines hétérogènes et attaquables à différents niveaux. Ces domaines sont vastes et présentent peu de recouvrement. Il n'est donc pas envisageable de sécuriser l'ensemble de la 5G et il est plutôt nécessaire de se focaliser sur des problématiques ciblant des parties restreintes de cet écosystème. Nous excluons ainsi de notre étude les problématiques de sécurité liées directement au network slicing, à la virtualisation ou à l'orchestration, qui nécessiteraient une analyse spécifique. Nous considérons plutôt ces mécanismes comme des vecteurs potentiels d'intrusion qui pourrait permettre à un attaquant de compromettre un ou plusieurs composants du réseau.

La softwarisation de la 5G est l'un des changements majeurs de cette génération et se reflète principalement sur les couches protocolaires hautes. C'est pourquoi nous avons choisi de concentrer le travail de cette thèse sur la partie applicative du trafic de contrôle transitant par le cœur et le RAN de la 5G. Les sections précédentes ont montré que la 5G est conçue pour être très modulaire, avec des nouvelles familles de NF pouvant être définies de manière arbitraire, notamment dans le cas des déploiements privés. Nous restreignons donc notre champ d'étude à un réseau comprenant uniquement les NF essentielles et géré par un seul opérateur.

Comme nous n'avons pas d'informations sur l'état de maturité ni sur les problématiques de déploiement rencontrées par les opérateurs publics, notre étude se base à la fois sur les deux seules sources d'information publiques à savoir la norme 3GPP et les implémentations open source. Nous supposons que ces implémentations open source sont bien moins matures que les déploiements réels des opérateurs commerciaux, mais nous faisons l'hypothèse que, étant donné la complexité du

système, même les réseaux 5G des opérateurs doivent s'écarter du standard à certains égards. De plus, dans le cadre de déploiements privés, il est tout à fait plausible que certaines organisations utilisent une version officielle ou dérivée d'implémentations open source.